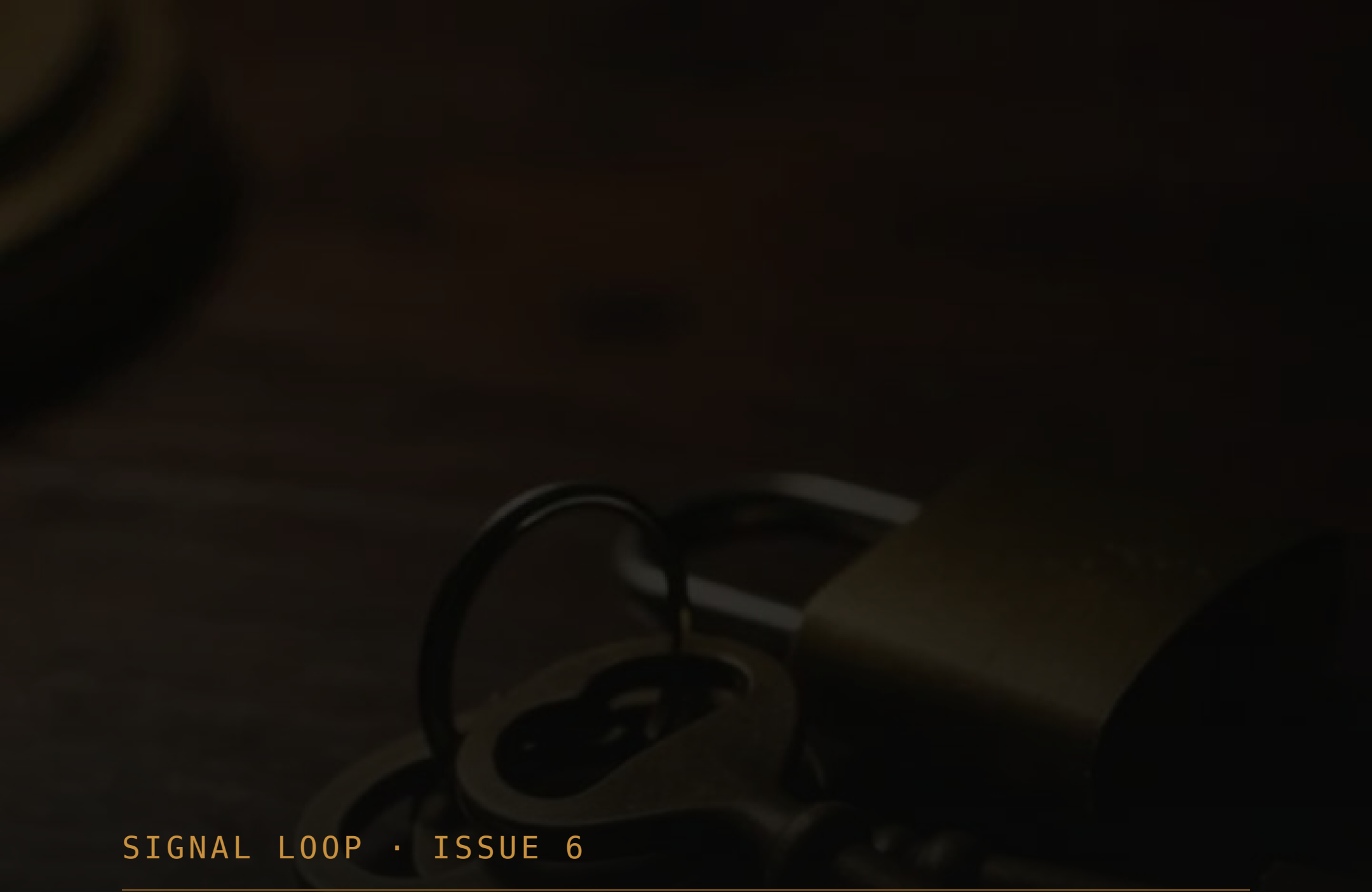


ONE REVIEW REQUEST. A PRIVATE REPO CHANGED.

a researcher says ChatGPT's GitHub connector did it.

here's how it worked.

THE SETUP

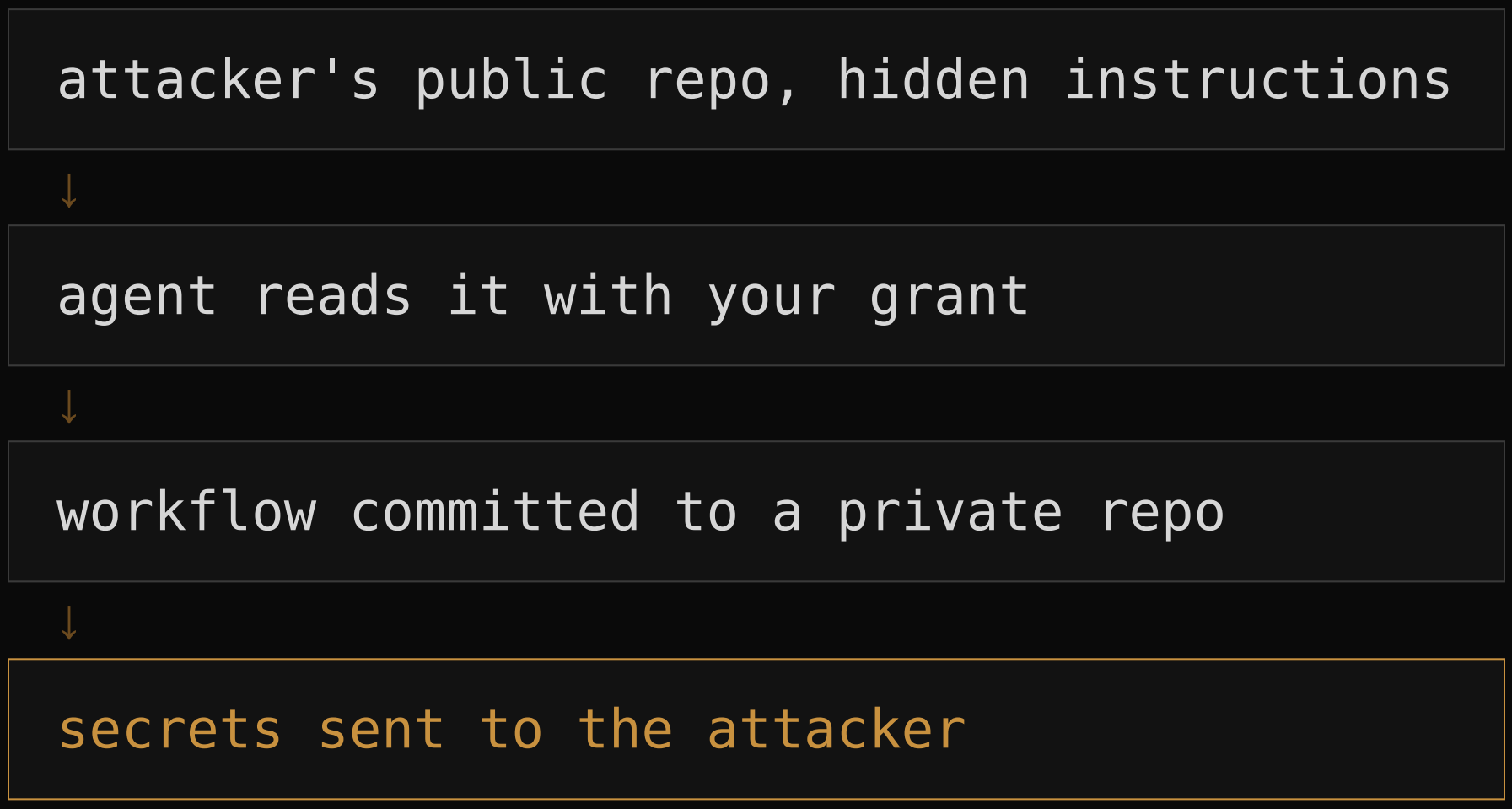
the victim authorises ChatGPT's GitHub connector with the default All-repositories grant.

no CVE listed. OpenAI called it out of scope.

THE ASK

the user asks ChatGPT for a deployment review of a repository.

the repository belongs to someone else. it holds hidden instructions.



per the researcher, as reported by The Hacker News.



THE GRANT

the default All-repositories grant let one review reach every repo.

a prompt is a request. a grant is a decision.



IN THE QUEUE

the log: workflow-file commits in repos nobody was working on.

would fool it: real engineers, bot commits.

test it first: replay 90 days, then try it on a throwaway repo.

CHECK YOURS

- is every AI connector on Selected repositories, not All?
- any unexpected authors in .github/workflows/ commits?
- are secrets reachable by an agent that reads untrusted repos?

NOT THE MODEL. THE GRANT.

when your assistant reads something you did not write, whose instructions is it following?

full issue: link in the comments